Ce qu'il ne faut pas faire

- Faire transiter des données personnelles dans une URL (ex. : identifiants, mots de passe).
- Utiliser des services non sécurisés (ex. : authentification en clair, flux en clair).
- Utiliser les serveurs hébergeant des sites web comme des postes de travail (ex. : navigation sur des sites web, accès à une messagerie électronique).
- Placer les bases de données sur un serveur directement accessible depuis Internet.
- Utiliser des comptes utilisateurs génériques (c'est-à-dire partagés entre plusieurs utilisateurs).

POUR ALLER PLUS LOIN

- Concernant la mise en œuvre de cookies, il est conseillé de consulter le dossier dédié sur le site de la CNIL[48].
- De manière générale, respecter les niveaux L1 et L2 des recommandations produites par l'OWASP[49].S'agissant des logiciels s'exécutant sur des serveurs, il est conseillé d'utiliser **des outils de détection des vulnérabilités** (logiciels de scans de vulnérabilité tels que OWASP ZAP[50], nmap[51] ou nikto[52]) pour les traitements les plus critiques afin de détecter d'éventuelles failles de sécurité. Des systèmes de détection et de prévention des attaques sur des systèmes ou serveurs critiques peuvent aussi être utilisés. Ces tests doivent être menés de façon régulière et avant toute mise en production d'une nouvelle version logicielle.
- **L'ANSSI a publié sur son site[53] des recommandations spécifiques** pour mettre en œuvre TLS[54] ou pour sécuriser un site web[55].

48 « Site web, cookies et autres traceurs », cnil.fr
49 « OWASP MAS Checklist », mas.owasp.org
50 « Zed Attack Proxy (ZAP) », zaproxy.org
51 « Nmap », nmap.org
52 « Nikto2 », cirt.net
53 « Publications de l'ANSSI », cyber.gouv.fr
54 « Recommandations de sécurité relatives à TLS », cyber.gouv.fr
55 « Sécuriser un site web », cyber.gouv.fr